

Compliance mapping (CIS L1 baseline; STIG only if required)

Compliance mapping (informational)

Engagement: Supports **SOW item 2** (RHEL standards, Track A). **Out of scope:** audit attestation, PCI ROC, regulator sign-off (client GRC). Master scope: [ENGAGEMENT-ALIGNMENT.md](#).

This document is not legal or regulatory advice. Work with GRC, Legal, and Internal Audit to validate controls. Golden image / OpenSCAP patterns in [ARCHITECTURE.md](#) are **optional reference** —not required for single-VM Workshop 1 stabilization.

Frameworks commonly referenced for US banks

Framework	Reference	Relevance to golden images
FFIEC IS Handbook	ithandbook.ffiec.gov	Secure configuration, patch management, change control for standard builds
FFIEC CAT	ffiec.gov/cyberassessmenttool.htm	Cybersecurity maturity assessment
NIST CSF 2.0	nist.gov/cyberframework	Identify, Protect, Detect, Respond, Recover
NIST SP 800-53 Rev. 5	csrc.nist.gov SP 800-53	CM-2, CM-6, SI-2, SI-3, SI-4, AU-* families
NIST SP 800-190	csrc.nist.gov SP 800-190	Container and image security
PCI DSS v4 (if CDE)	pcisecuritystandards.org	Requirement 2 (secure configs), 6 (secure development), 10 (logging)
GLBA Safeguards	FTC Safeguards Rule	Administrative/technical safeguards for customer information systems
SOX ITGC	COSO Framework	Change management evidence for production OS standards
CIS Benchmarks	CIS RHEL 9	Primary OS baseline — RHEL 9 Level 1 in AIB
DISA STIG	cyber.mil STIGs	DoD-oriented; use only if client GRC mandates — assess separately from CIS

Full link index: [INDUSTRY-REFERENCES.md](#)

Control mapping (selected)

Control intent	Pipeline artifact
Standardized build	Terraform modules + version-pinned SIG
Least functionality	Package minimization, legacy protocol removal in AIB shell steps
Secure baseline	OpenSCAP CIS L1 profile + SELinux enforcing (STIG only if GRC requires)
Vulnerability gates	P0 remediated on dev before UAT; re-scan before prod — client security owns execution
Vulnerability management	<code>dnf update --security</code> during build; dnf-automatic (security-only); recurring rebuild cadence
Audit logging	auditd rules + audisp syslog; journald/rsyslog rotation and <code>/var/log/archive</code> ; forward at deploy via Azure Monitor DCR
Integrity monitoring	AIDE baseline in image; EDR at deploy time
Identification & authentication	SSH key-only, root locked, break-glass account provisioned
Change traceability	Git-versioned IaC, Terraform state, AIB logs to Log Analytics
Segregation of duties	Pipeline SPN/MI separate from production workload identities

Evidence for auditors

Retain per build:

1. Terraform plan/apply logs (CI system)
2. Azure Image Builder `lastRunStatus` and diagnostic logs
3. `/opt/compliance/artifacts/cis-verify-results.xml` (from built image or test VM)
4. SIG version ID and replication regions
5. Change ticket linking image version to production promotion

FIPS 140 considerations

FIPS mode affects application compatibility (Java, TLS ciphers, etc.). This pipeline enables FIPS-oriented steps but defaults supplemental crypto policy to **off** in Ansible until your crypto board approves. Validate in non-production before enforcing `FIPS` or `FIPS:OSPP` policies.

Data residency

Pin `location` and `replication_regions` to US regions approved by your data residency policy. SIG replication is explicit in Terraform variables.

Third-party software

- **Red Hat:** BYOS subscription and support entitlements are your responsibility.
- **CIS:** Optional Marketplace images are licensed separately from CIS.
- **OpenSCAP content:** Shipped via `scap-security-guide` RPM; profile versions track RHEL minor releases.

Gaps requiring organizational process (not IaC alone)

The following are **client-owned**; not Vaco SOW deliverables unless separately contracted:

- Incident response playbooks for compromised golden image
- Vulnerability scanning of SIG versions (e.g., Defender for Cloud, Qualys from test VM)
- Penetration test scope including standard build (**out of scope** — client or third party)
- Vendor risk management for Azure and Red Hat
- Privileged access management for break-glass accounts
- Regulatory or audit **attestation** (**out of scope** — client GRC)

Industry references

See [INDUSTRY-REFERENCES.md](#) for Azure, Red Hat, Podman, and supply-chain authorities referenced by mapped controls.